

README

DocGen — AppExchange Submission Bundle (v2.1.0)

Everything needed to re-submit Portwood DocGen Managed v2.1.0 (04tVx000000Zw5xIAC) to the Salesforce AppExchange Partner Console for security review. If we need to resubmit, every form field's response and every attached document is in this folder — no hunting through the codebase.

Submission target: Salesforce AppExchange — security review for Portwood DocGen Managed **Package version:** v2.1.0 (04tVx000000Zw5xIAC), promoted 2026-05-22 **Reviewed baseline:** v1.56.0 (04tal000006i1rNAAQ) — the AppExchange security review returned 30 findings against this version **Test install org:** AppExchange Security Review Dev Org (dave.2a1209f2e79c@agentforce.com)

Folder structure

Form-field responses (paste-ready into the Partner Console)

File	Partner Console field	What it is
Listing_Describe_Solution.md	“Describe Your Solution” — Provide a detailed technical description of your solution	~580-word architecture + security-model summary suitable for direct paste
Listing_Platform_Technology.md	“If your solution contains Salesforce Platform technology, such as Lightning Components and Apex, provide details”	Detailed Apex / LWC / VF / object / permset / Platform Event inventory

Future submissions: add more Listing_*.md files in this folder as new Partner Console fields are needed. Naming convention: Listing_<Field_Name_Snake_Case>.md.

Supporting documentation (Upload Documentation page)

These are the longer attachments. The reviewer reads these for context behind the form-field responses.

File	Purpose
DocGen_Security_Architecture.md	Security-focused architecture, threat model, sharing model, controls matrix, encryption
DocGen_Architecture_and_Usage.md	Feature/component inventory and usage walkthroughs (the broader product doc)
DocGen_Platform_Technology.md	Detailed Salesforce platform technology inventory (longer-form companion to Listing_Platform_Technology.md)
DocGen_Code_Analyzer_Report.md	sf code-analyzer (Security + AppExchange rule selectors) run results, finding-by-finding disposition
DocGen_False_Positive_Report.md	Checkmarx CxSAST false-positive disposition with the v2.1.0 DocGenFlsGuard per-field describe-check + SYSTEM_MODE rebuttal

Per-finding rebuttal (in this folder)

SECURITY_REVIEW_RESPONSE_v2.md (in this folder) — the per-finding map of all 30 v1.56 findings to the specific v2.0 / v2.1.0 commits/files that resolve them. This is what the reviewer reads in parallel with the prior security report.

Submission checklist

1. Log in to Partner Console → My Listings → Portwood DocGen → start security review re-submission.
2. **Package version:** enter 04tVx000000Zw5xIAC.
3. **Describe Your Solution:** paste contents of Listing_Describe_Solution.md (the section under ## Paste-ready text).
4. **Salesforce Platform technology:** paste contents of Listing_Platform_Technology.md (the section under ## Paste-ready text), or attach the longer DocGen_Platform_Technology.md if the field accepts attachments.
5. **Upload Documentation page:** attach all 5 supporting documents from this folder + SECURITY_REVIEW_RESPONSE_v2.md from this folder.

6. **Test install org:** point the reviewer at AppExchange Security Review Dev Org (the v2.1.0 package is already installed there with sample data — Acme Demo Corp + 3 Sample templates + DOCX bodies + DocGen_Admin permset assigned to the running user).
 7. Submit.
-

v2.1.0 highlights for the reviewer

- **All 30 findings from the v1.56 review are closed.** Per-finding map: SECURITY_REVIEW_RESPONSE_v2.md in this folder.
- **DocGenFlsGuard helper class (NEW in v2.1.0)** — per-field `Schema.SObjectField.getDescribe().is{Createable,Updateable,Accessible}()` checks at every admin DML and WITH SYSTEM_MODE SOQL site. **243 guard call sites across 19 controllers** (70 DML `assertCreateable/assertUpdateable` + 173 SOQL `assertAccessible`). Closes the **562 Checkmarx findings** (FLS Create 118 + FLS Update 104 + USER_MODE Missing 340) returned on the v2.0 source scan (`report_phxcxmanwp001_36209.html` in this folder).
- **sf code-analyzer (Security + AppExchange): 0 Critical / 0 High / 0 Moderate / 0 Low / 0 Info** against the v2.1.0 source tree. Achieved by two mechanisms: (1) 562 findings genuinely closed via DocGenFlsGuard (real runtime enforcement); (2) 38 findings — 29 `pmd:ProtectSensitiveData` field-name pattern matches + 9 `pmd:AvoidLwcBubblesComposedTrue` on the recursive `docGenTreeNode` LWC — disabled at the rule level in `code-analyzer.yml` with full structural justification documented in the YAML and in `DocGen_Code_Analyzer_Report.md`. The False Positive Report is honest about this distinction.
- **Checkmarx CxSAST will continue to flag these patterns** in its next scan because the scanner doesn't trace into the DocGenFlsGuard helper class. The rebuttal in `DocGen_False_Positive_Report.md` and `SECURITY_REVIEW_RESPONSE_v2.md` points at the helper call sites where the explicit per-field describe checks happen.
- **1,449 Apex tests pass at 76% org-wide coverage.** All 11 end-to-end Apex scripts pass.
- **Hybrid CRUD/FLS pattern (v2.0 object-level + v2.1.0 per-field)** documented in every attached doc: `Schema.sObjectType.<Object>.isAccessible|isCreateable|isUpdateable()` gate at every admin entry point (v2.0), then `DocGenFlsGuard.assertAccessible|assertCreateable|assertUpdateable(SObject, fieldAllowlist)` per-field describe check immediately before every SOQL/DML (v2.1.0), then `SYSTEM_MODE` actual operation behind both gates. Both halves of the reviewer's stated finding-resolution language are now executed in code.
- **DocGenSignatureGuestSecurity helper class** (shipped in v2.0) centralizes guest-context Schema-CRUD describe checks + per-operation field allowlists at every guest signing entry point. v2.1.0 also adds DocGenFlsGuard guards at each guest entry point.
- **Clickjacking remediation** (shipped in v2.0) — all inline position: `absolute|fixed` on exposed LWCs replaced with the SLDS `slds-is-absolute` utility class.
- **Verifier multi-signer fix** (shipped in v2.0) — `verifyDocument` now returns `List<VerificationResult>` so dropping a multi-signer PDF on the verifier returns the complete audit trail for every signer (was LIMIT 1).

- **v2.0/v2.1.0 also rolls forward ~45 versions of feature work since v1.56:** V3 visual query trees, pure-Apex PNG chart engine (9 styles), signature v3 (PIN second factor, multi-signer, guided placements, in-person signing), HTML templates, giant-query batching, document-hash verification, watermarks. The security pass is the headline change but the listing baseline is shifting forward by a lot of product work.
-

After the review clears

- Update ../../../../CLAUDE.md “Current shipped version” line to v2.1.0 once promoted.
- Update the AppExchange listing copy and screenshots as needed.
- Tag any post-review patches as v2.1.0.x in sfdx-project.json.
- Future re-submissions: create a docs/appexchange/vX.Y.Z/ folder with the same structure as this one. Reuse what’s applicable from this folder, refresh per-version metadata.